

● CRITICAL SEVERITY

RANSOMWARE ATTACK

INCIDENT RESPONSE PLAYBOOK

ORGANIZATION	University of Delaware
PREPARED BY	Kavya Sri Reddy
GENERATED	2026-05-27 15:48:38
NIST FUNCTIONS	Detect, Respond, Recover
SLA — CONTAINMENT	2 hours
SLA — RESOLUTION	2 weeks

INCIDENT DESCRIPTION

Malware that encrypts victim files and demands payment for decryption keys. Can spread laterally across networks causing widespread business disruption.

MITRE ATT&CK; TACTICS

- Execution (TA0002)
- Lateral Movement (TA0008)
- Impact (TA0040)

INDICATORS OF COMPROMISE (IOCs)

- Encrypted file extensions
- Ransom note filenames
- C2 IP/domains
- Malware hashes
- Anomalous SMB traffic

ESCALATION MATRIX

SEVERITY	ESCALATION PATH
Low	N/A — Ransomware is always High or Critical
High	CISO + IT Director + Legal
Critical	CEO + Board notification + Law enforcement (FBI IC3) + Cyber insurance carrier

PHASE: IDENTIFICATION [0–30 minutes]

NIST Control: DE.CM-4 — Malicious code is detected

TOOLS: EDR, SIEM, File integrity monitor, Network traffic analysis

RESPONSE STEPS

- 1 Detect via EDR alert, user report, or file integrity monitoring
- 2 Identify the affected host(s) and user accounts
- 3 Determine ransomware variant if possible (ransom note, file extension)
- 4 Check if encryption is still active or has completed
- 5 Identify patient zero — the initial infected system
- 6 Assess scope: number of systems affected, data encrypted

PHASE: CONTAINMENT [30 min – 2 hours]

NIST Control: RS.MI-1 — Incidents are contained

TOOLS: Network switch/VLAN controls, Firewall, AD, Forensic imaging tools

RESPONSE STEPS

- 1** IMMEDIATELY isolate affected systems from network (disable NIC or VLAN)
- 2** Disable shared drives and network file shares enterprise-wide
- 3** Block C2 IP addresses and domains at firewall
- 4** Disable affected user accounts in Active Directory
- 5** Preserve memory dumps and disk images before shutdown for forensics
- 6** Notify IT leadership and activate IR team
- 7** Do NOT pay ransom without executive and legal approval

PHASE: ERADICATION [2–48 hours]

NIST Control: RS.MI-2 — Incidents are mitigated

TOOLS: EDR, Vulnerability scanner, AD, Patch management

RESPONSE STEPS

- 1 Identify the initial attack vector (phishing, RDP brute force, vulnerability)
- 2 Remove ransomware binary from all affected systems
- 3 Patch or remediate the exploited vulnerability immediately
- 4 Audit and rotate ALL privileged credentials enterprise-wide
- 5 Check for persistence mechanisms (scheduled tasks, registry keys, startup items)
- 6 Rebuild systems from scratch if encryption was extensive

PHASE: RECOVERY [48 hours – 2 weeks]

NIST Control: RC.RP-1 — Recovery plan is executed

TOOLS: Backup and recovery platform, SIEM, Compliance management

RESPONSE STEPS

- 1 Restore data from last known clean backup
- 2 Verify backup integrity BEFORE restoring to production
- 3 Restore systems in priority order (critical business systems first)
- 4 Monitor restored systems closely for 7 days
- 5 Notify regulatory bodies if PII/PHI was exposed (GDPR/HIPAA requirements)
- 6 Communicate status to business stakeholders daily

PHASE: LESSONS LEARNED [Within 2 weeks]

NIST Control: RC.IM-2 — Recovery strategies are updated

TOOLS: Documentation platform, Network architecture review, Insurance portal

RESPONSE STEPS

- 1 Conduct full post-mortem with C-suite, IT, legal, and HR
- 2 Document complete attack timeline from initial access to containment
- 3 Review backup frequency and offsite/offline backup strategy
- 4 Assess network segmentation gaps that allowed lateral movement
- 5 Update IR plan and runbooks based on gaps identified
- 6 Consider cyber insurance claim if applicable